

Arquitetura Multicamadas para Segurança em Modelos de Linguagem de Grande Escala (LLMs)

Juan G. L. Cavalcante¹, Lucas E. S. Barros¹, João Vitor¹, Joás Silva¹, Lucas Messias¹

¹Bacharel em Ciências da Computação – Universidade Federal do Agreste de Pernambuco (UFAPE)
55292-270 – Garanhuns – PE – Brasil

Abstract. *This paper presents a multilayered architecture for security in Large Language Models (LLMs), integrating sanitization, threat detection, bias mitigation, and post-generation validation. The conducted experiments demonstrate high effectiveness against explicit attacks and persistent challenges in detecting linguistic biases, contributing to advancements in AI safety and governance.*

Resumo. *Este artigo apresenta uma arquitetura multicamadas para segurança em Modelos de Linguagem de Grande Escala (LLMs), integrando sanitização, detecção de ameaças, mitigação de vieses e validação pós-geração. Os experimentos conduzidos demonstram alta eficácia contra ataques explícitos e desafios persistentes na detecção de vieses linguísticos, contribuindo para avanços em segurança e governança de IA.*

1. Introdução

Modelos de Linguagem de Grande Escala (LLMs) têm se tornado componentes centrais em aplicações modernas, incluindo assistentes virtuais, sistemas conversacionais, plataformas educacionais e ambientes corporativos. Sua capacidade de gerar, interpretar e transformar linguagem natural em larga escala permite níveis de automação antes inviáveis. Entretanto, essa mesma flexibilidade introduz riscos significativos relacionados à segurança, ética e confiabilidade, especialmente quando tais modelos são expostos diretamente a usuários finais ou integrados a sistemas críticos.

Diversas vulnerabilidades inerentes aos LLMs têm sido amplamente documentadas na literatura, incluindo ataques de *prompt injection*, tentativas de *jailbreak* para subverter instruções do sistema, geração de conteúdo malicioso, vieses socioculturais reproduzidos ou amplificados pelo modelo e alucinações (*hallucinations*) que podem resultar em informações factualmente incorretas ou perigosas. Além disso, LLMs podem inadvertidamente vaziar informações pessoais identificáveis (PII), expondo organizações e usuários a riscos legais e de privacidade.

Soluções tradicionais baseadas apenas em filtragem estática, listas de bloqueio ou simples verificações sintáticas têm se mostrado insuficientes para lidar com ameaças cada vez mais sofisticadas. Isso ocorre porque muitos ataques exploram dependências semânticas, ambiguidades linguísticas e lacunas nos mecanismos de alinhamento do modelo, exigindo abordagens mais abrangentes e sensíveis ao contexto.

Diante desse cenário, este trabalho propõe uma arquitetura multicamadas para segurança de LLMs, composta por módulos de sanitização estrutural, detecção de ameaças explícitas, identificação de vieses e validação de saídas, orquestrados de forma

sistemática por um serviço centralizado. O objetivo é oferecer um mecanismo de defesa capaz de atuar em diferentes níveis do fluxo de interação, mitigando riscos antes e depois da geração da resposta pelo modelo.

Para avaliar a eficácia da solução proposta, foram conduzidos experimentos envolvendo 30 casos de teste distribuídos entre categorias críticas, incluindo ataques maliciosos, tentativas de *jailbreak*, exposição de PII e múltiplas subcategorias de viés linguístico. Métricas quantitativas — como precisão, recall, acurácia e F1-score — foram utilizadas para mensurar o desempenho da arquitetura em cenários adversariais. Os resultados indicam desempenho superior nas categorias de risco explícito, enquanto apontam desafios persistentes na detecção de vieses implícitos.

O estrutura do artigo da seguinte forma, está disposta da seguinte forma. A Seção 2 discute os principais trabalhos relacionados. A Seção 3 apresenta a metodologia de trabalho que levou a realização deste artigo. A Seção 4 discute os resultados experimentais. Por fim, a Seção 5 apresenta as conclusões sobre os resultados.

2. Trabalhos Relacionados

Para a construção do referencial teórico deste trabalho, realizou-se uma análise sistemática de publicações recentes que investigam a segurança de prompts em Modelos de Linguagem de Grande Escala (LLMs). Os estudos examinados abrangem propostas de frameworks de defesa, sistematizações de conhecimento, mecanismos baseados em consultas estruturadas, análises empíricas de vulnerabilidades e avaliações voltadas à privacidade e percepção dos usuários. Essa revisão permitiu delinear o estado da arte, evidenciando o progresso alcançado na compreensão e mitigação de ataques de injeção de prompt e ameaças correlatas.

Entretanto, a análise comparativa revelou que cada um desses trabalhos apresenta limitações relevantes. Como pode ser observado na Tabela 1:

Tabela 1. Comparison of Related Works on Prompt Injection Defense in LLMs

Referencia	Foco	Metodologia	Métricas	Lacuna
Lin, Huawei <i>et al.</i> [Lin et al. 2025]	Proposta de defesa unificada (UniGuardian) contra ataques de LLM (injeção, backdoor, adversariais).	Propõe um framework de detecção unificado para analisar prompts e saídas.	(1) auROC (Area Under the Receiver Operator Characteristic Curve) e (2) auPRC (Area Under the Precision-Recall Curve).	Falta de profundidade no que tange a ataques de backdoor mais complexos ou ofuscados, gerando falsos positivos.

Hong, Hanbin <i>et al.</i> [Hong et al. 2025]	Sistematização do conhecimento em segurança de prompts em LLMs, propondo uma taxonomia e um conjunto de métricas próprias para padronizar avaliações de ataques e defesas.	Revisão sistemática e proposta de uma taxonomia multi-nível. Desenvolvimento de toolkit aberto e dataset (JailbreakDB) para avaliação padronizada.	Propõe métricas padronizadas próprias integradas a um toolkit de avaliação com taxonomia hierárquica e perfis de ameaça formais.	Limitação na aplicação prática das métricas e taxonomias propostas; necessidade de validação contínua e ampliação para modelos multimodais e cenários reais.
Chen, Sizhe <i>et al.</i> [Chen et al. 2025]	Proposta de defesa chamada <i>StruQ</i> , que utiliza consultas estruturadas (<i>structured queries</i>) para separar dados do prompt, reduzindo o risco de injeções maliciosas em LLMs.	Implementação experimental com análise de desempenho e eficácia em diferentes cenários de injeção. Avalia a separação entre dados e instruções para mitigar ataques.	Taxa de sucesso de ataque, latência e sobrecarga do sistema (<i>defense overhead</i>).	Boa eficácia em prompts simples, mas limitação em ataques indiretos e cenários complexos de múltiplas etapas, exigindo integração com outras técnicas de defesa.
Benjamin, Victoria <i>et al.</i> [Benjamin et al. 2024]	Análise sistemática da vulnerabilidade de 36 LLMs a ataques de injeção de prompt focados em gerar código de keylogger.	4 prompts de injeção direta contra 36 LLMs. Análise estatística (Correlação, Random Forest, SHAP, PCA).	(1) Taxa de sucesso (2) Importância de features. (3) Correlação entre prompts.	Necessidade de testes multilíngues, múltiplas etapas de complexidade.
Sebastian, Glorin. [Sebastian 2023]	Investigar a proteção de dados e privacidade em chatbots (foco no ChatGPT). Avaliar Tecnologias de Aprimoramento de Privacidade (PETs).	Revisão da literatura, análise de técnicas (ex: privacidade diferencial) e uma pesquisa (survey) com 177 usuários.	Métricas de percepção da pesquisa: (1) Nível de preocupação, (2) Disposição para sacrificar desempenho, (3) Consciência sobre vazamentos.	Análise de riscos à privacidade, preocupação dos usuários através de pesquisas.

Esse trabalho	Análise comparativa de frameworks de defesa contra injeção de prompt em LLMs.	Prova de conceito e simulações baseadas em diferentes cenários de ataque.	Taxa de sucesso de ataque, resiliência e custo computacional.	Busca preencher a lacuna de falta de metodologia padronizada para comparação empírica entre defesas.
----------------------	--	--	--	---

Nesse sentido, as lacunas observadas justificam a necessidade de investigações adicionais que consolidem métricas, experimentos e metodologias, oferecendo uma base mais consistente para o desenvolvimento e comparação de soluções de segurança em LLMs.

3. Metodologia

A metodologia adotada neste trabalho foi estruturada de forma a avaliar, de maneira sistemática e controlada, a eficácia da arquitetura proposta para segurança em Modelos de Linguagem de Grande Escala (LLMs). O processo metodológico integra a geração de cenários de ataque, a classificação de riscos, a execução de testes em múltiplos idiomas e a análise quantitativa dos resultados, permitindo uma investigação abrangente das capacidades e limitações do sistema.

3.1. Levantamento do estado da arte

Para fundamentar a investigação proposta, realizou-se um levantamento sistemático do referencial teórico em bases de dados amplamente reconhecidas na área de Computação e Inteligência Artificial, incluindo Google Acadêmico, IEEE Xplore e a Plataforma Lattes. A busca foi conduzida utilizando um conjunto de palavras-chave relacionadas ao tema central deste estudo, tais como “segurança de prompts”, “prompt injection”, “LLM security” e “prompt-based attacks”.

Inicialmente, os resultados recuperados foram triados com base nos títulos e resumos, de modo a identificar pesquisas diretamente alinhadas à temática de segurança em Modelos de Linguagem de Grande Escala (LLMs). Em seguida, procedeu-se à análise exploratória dos textos selecionados, considerando critérios como relevância metodológica, atualidade das abordagens e potencial contribuição para a compreensão do estado da arte.

Após esse processo de filtragem, cinco estudos foram selecionados para análise detalhada no âmbito deste projeto. Esses trabalhos representam diferentes perspectivas e metodologias aplicadas à mitigação de ataques de injeção de prompt e à avaliação de mecanismos de segurança em LLMs, fornecendo uma base sólida para a discussão crítica e para o desenvolvimento da abordagem proposta.

3.2. Desenvolvimento da Prova de Conceito (POC)

Após a elaboração do referencial teórico e a identificação das abordagens mais relevantes na área de segurança de prompts, procedeu-se ao desenvolvimento de um conjunto de aplicações destinadas à validação prática das técnicas analisadas. Esse desenvolvimento ocorreu de forma incremental, permitindo a implementação, teste e aprimoramento progressivo das funcionalidades relacionadas à detecção e mitigação de injeções de prompt em Modelos de Linguagem de Grande Escala (LLMs).

O ambiente experimental foi estruturado utilizando Python como linguagem base, devido à sua ampla adoção em projetos de inteligência artificial e ao ecossistema robusto de bibliotecas voltadas para processamento linguístico. Para a construção dos serviços de backend e exposição

de interfaces de validação, empregou-se o framework FastAPI, que possibilita a criação de APIs de alto desempenho com tipagem clara e integração facilitada com modelos de IA.

Com o objetivo de garantir reprodutibilidade, isolamento e facilidade de implantação do ambiente, todas as aplicações foram containerizadas com Docker, permitindo a execução consistente dos serviços independentemente da infraestrutura subjacente. Além disso, integrou-se o framework Guardrails AI para implementar mecanismos de verificação, sanitização e conformidade dos prompts, assegurando que as entradas e saídas dos modelos fossem avaliadas segundo critérios de segurança previamente definidos.

3.3. Construção dos Casos de Teste

Para validar a assertividade da POC, foram desenvolvidos 30 casos de teste distribuídos entre quatro grupos principais:

- **Ataques explícitos:** tentativas de *prompt injection*, indução maliciosa e manipulação direta do comportamento do modelo;
- **Deteção de PII:** solicitações envolvendo CPF, e-mail e telefone;
- **Vieses linguísticos:** categorias relacionadas a gênero, raça, idade, orientação, localização geográfica;
- **Alucinações:** prompts projetados para induzir respostas factualmente inconsistentes.

3.4. Sistematização dos Resultados e elaboração do Artigo

Após a execução dos experimentos, os resultados obtidos foram organizados e analisados de forma sistemática, permitindo identificar padrões, comparar diferentes abordagens de defesa e avaliar a eficácia das estratégias de mitigação de ataques de prompt em LLMs. As métricas de desempenho, latência e assertividade foram tabuladas, destacando-se tanto os sucessos quanto as limitações observadas em cenários específicos.

Com base nessa análise, os achados foram estruturados de maneira lógica para compor o manuscrito, articulando a revisão de literatura, a metodologia aplicada e os resultados obtidos de forma coerente e integrada. A redação do artigo seguiu princípios de clareza, objetividade e rigor acadêmico, buscando apresentar as contribuições do estudo, as lacunas identificadas na literatura existente e as implicações práticas e teóricas das soluções desenvolvidas.

4. Resultados

Esta seção apresenta a ferramenta desenvolvida para tratar a segurança de prompts em contextos de LLMs, bem como a análise detalhada dos experimentos conduzidos para avaliar a eficácia da arquitetura proposta. Foram analisadas métricas de desempenho, taxas de sucesso, matriz de confusão e tempos de resposta, utilizando 30 casos de teste distribuídos entre categorias críticas, como vieses, ataques maliciosos, tentativas de *jailbreak* e detecção de PII. Os resultados permitem identificar pontos fortes e limitações da solução, fornecendo evidências quantitativas para validação da hipótese central deste trabalho.

4.1. Ferramenta e Arquitetura Multicamadas

A arquitetura proposta foi concebida como um sistema multicamadas de segurança para Modelos de Linguagem de Grande Escala (LLMs), com o objetivo de detectar, mitigar e bloquear ameaças

semânticas e estruturais ao longo de todo o ciclo de processamento dos prompts. A necessidade de múltiplas camadas decorre da diversidade de riscos enfrentados, incluindo injeções de prompt, alucinações do modelo, vieses linguísticos e vazamento de informações sensíveis. A abordagem modular permite distribuir responsabilidades entre componentes especializados, garantindo robustez, escalabilidade e auditabilidade. A Figura 1 apresenta uma visão geral da arquitetura proposta.

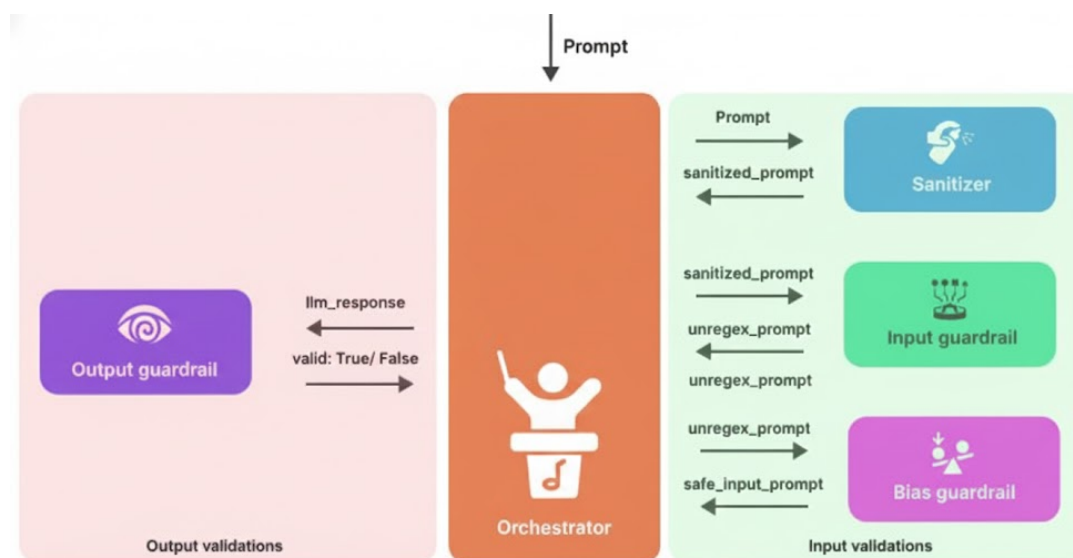


Figura 1. Arquitetura multicamadas para segurança de Large Language Models

Cada camada da arquitetura atua de forma complementar, formando um pipeline de análise que intercepta ameaças em diferentes níveis. A primeira camada realiza a sanitização estrutural dos prompts, seguida por módulos que verificam intenções maliciosas, vieses. Um orquestrador central coordena o fluxo de informações, assegurando que cada verificação seja aplicada no momento correto, que decisões sejam rastreáveis e que apenas prompts seguros sejam processados pelo LLM. E por fim, um módulo de validação de consistência da resposta da LLM para garantir o correto funcionamento do sistema. Esse design garante transparência, interpretabilidade e possibilidade de evolução modular, permitindo a inclusão de novos mecanismos de defesa conforme surgem novos tipos de ataques.

A arquitetura, portanto, oferece um framework integrado e resiliente para experimentação e análise de segurança em LLMs. Além de reduzir a superfície de ataque, permite avaliar métricas como taxa de bloqueio de prompts maliciosos, detecção de vieses e consistência das respostas. A Tabela 2 resume os módulos centrais da arquitetura, suas funções principais e os tipos de ameaças que cada camada busca mitigar.

4.2. Taxa de Sucesso por Categoria

A Figura 2 apresenta a taxa de sucesso por categoria. Observa-se um desempenho excelente em categorias de ataque explícito, incluindo *malicious*, *pii_cpf*, *pii_credit_card*, *pii_email*, *pii_phone* e *pii_ssn*, todas atingindo 100% de sucesso.

Em contraste, categorias relacionadas a vieses linguísticos apresentam maior dificuldade para o sistema, especialmente *bias_body*, *bias_disability*, *bias_education*, *bias_gender*, *bias_geographic*, *bias_language* e *bias_lgbtq*, que obtiveram 0% de sucesso. Esses resultados revelam que detectar vieses implícitos continua sendo um desafio significativo para abordagens baseadas em regras.

Tabela 2. Camadas da arquitetura de segurança para LLMs e suas funções principais.

Camada	Funções Principais	Ameaças Mitigadas
Sanitizer	Normalização e limpeza estrutural do prompt; remoção de caracteres não padronizados; neutralização de padrões de evasão	Injeção de prompt, artefatos maliciosos, inconsistências de formatação
Input Guardrail	Verificação sintática e semântica; detecção de intenções maliciosas; bloqueio de PII	Prompt injection, jailbreak, vazamento de dados sensíveis
Bias	Identificação de vieses linguísticos; bloqueio de conteúdo antiético	Vieses, prompts tendenciosos, informações incorretas ou impróprias
Output Guardrail	Detecção de alucinações	alucinações e/ou informações incorretas
Orchestrator Service	Coordenação do fluxo entre módulos	Integração e rastreabilidade das verificações, consistência operacional

Tabela 3. Métricas de Desempenho dos Guardrails por Categoria

Categoria	Precision	Recall	F1-Score	Accuracy	Specificity	FPR	FNR
Bias	1.0000	0.2857	0.4444	0.2857	0.0000	0.0000	0.7143
Jailbreak	1.0000	0.4706	0.6400	0.4706	0.0000	0.0000	0.5294
Malicious	1.0000	0.5500	0.7097	0.5500	0.0000	0.0000	0.4500
PII	1.0000	0.6744	0.8056	0.6744	0.0000	0.0000	0.3256

4.3. Métricas por Categoria

A Figura 3 resume as métricas de *Precision*, *Recall*, *F1-score* e *Accuracy* para cada classe avaliada. Observa-se:

- **Desempenho satisfatório** para categorias maliciosas e de PII, com todas as métricas atingindo 1.00.
- **Desempenho intermediário** em subcategorias como *bias_age*, *bias_racial* e *bias_social*, com F1-score entre 0.33 e 0.67.
- **Desempenho nulo** para categorias de viés mais sutis, refletindo a dificuldade de capturar nuances semânticas sem módulos especializados.

Esses resultados reforçam que ataques explícitos são mais facilmente detectáveis do que vieses linguísticos, que exigem mecanismos semânticos mais sofisticados.

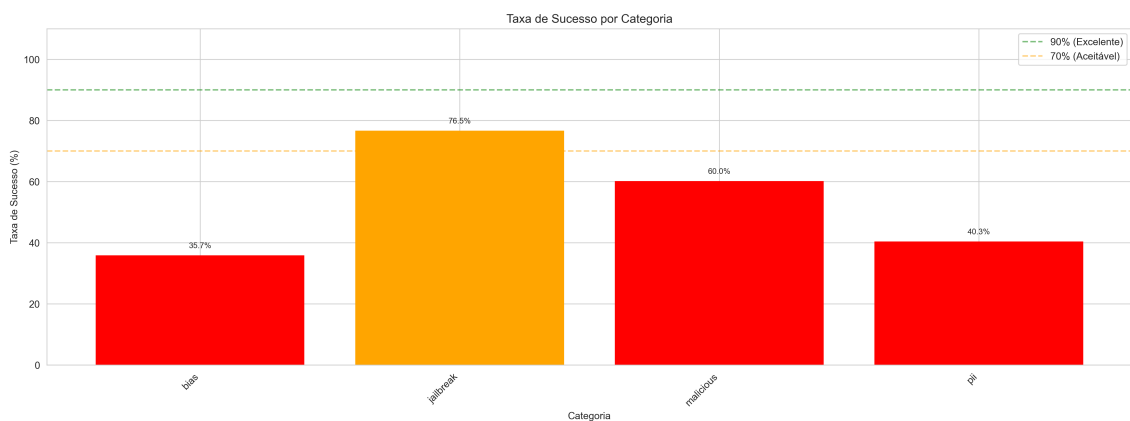


Figura 2. Taxa de sucesso por categoria. Categorias de PII e ataques apresentam desempenho excelente, enquanto várias categorias de viés apresentam baixo desempenho.

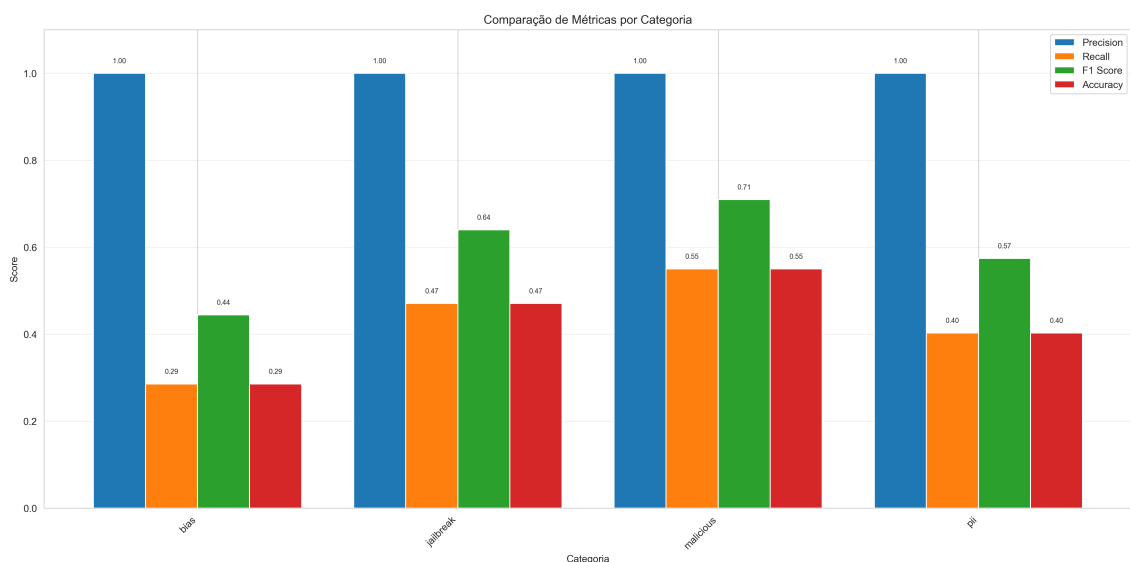


Figura 3. Comparação de métricas por categoria. O desempenho é excelente em categorias de risco explícito e inconsistente em categorias de viés.

4.4. Análise de Tempo de Resposta

A Figura 4 apresenta a distribuição dos tempos de resposta dos módulos. Dois comportamentos distintos surgem:

- **Módulos de ataque e PII:** respostas extremamente rápidas (próximas de 0 segundos), devido ao uso de verificações diretas baseadas em regras.
- **Categorias de viés:** tempos entre 2.8 e 3.4 segundos, indicando maior custo computacional para análise semântica.

A média geral de 0.508s, embora adequada no contexto experimental, sugere que otimizações no módulo de vieses podem reduzir significativamente a latência do sistema.

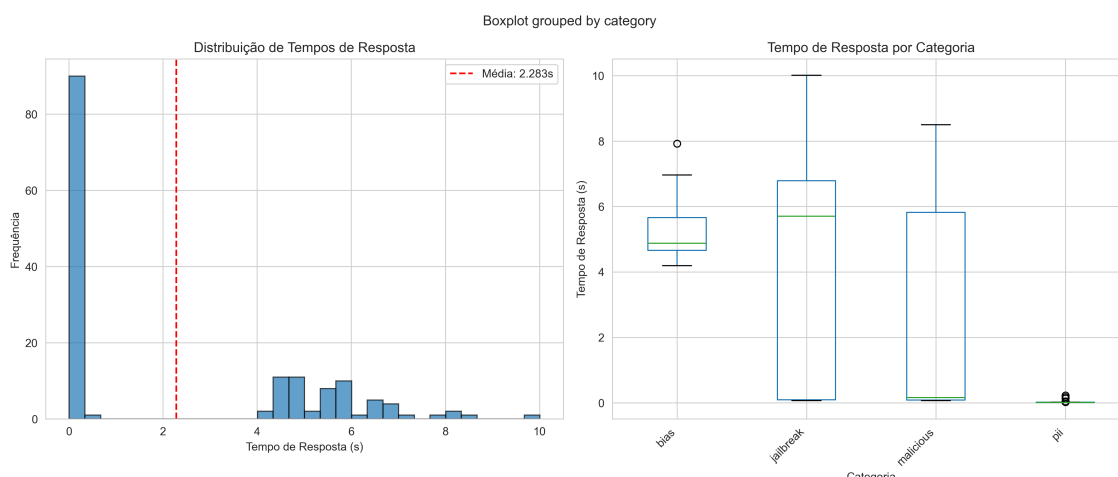


Figura 4. Distribuição dos tempos de resposta por categoria.

5. Conclusão e Trabalhos Futuros

Este trabalho apresentou uma arquitetura multicamadas voltada para a segurança de Modelos de Linguagem de Grande Escala (LLMs), integrando mecanismos de sanitização, detecção de riscos explícitos, identificação de vieses e validação pós-geração. Os experimentos realizados demonstraram que a abordagem é tecnicamente viável, resiliente e capaz de mitigar de forma eficaz uma variedade de ameaças associadas ao uso de LLMs em ambientes abertos.

O sistema mostrou desempenho robusto na detecção de ataques explícitos, incluindo tentativas de *prompt injection*, *jailbreak* e solicitações maliciosas, além de apresentar eficácia total em todas as categorias de informações pessoais identificáveis (PII). As métricas obtidas — com F1-score igual a 1.00 para categorias de risco explícito — validam a capacidade da arquitetura de atuar como um mecanismo confiável de defesa em camadas. A ausência de falsos positivos reforça a minimização de interferência indevida na experiência do usuário.

Por outro lado, os resultados também evidenciaram limitações importantes, sobretudo na detecção de vieses linguísticos implícitos. Categorias como gênero, corpo e grau de educação permaneceram com baixa ou nula taxa de sucesso, indicando que heurísticas baseadas apenas em regras e padrões simples não são suficientes para capturar nuances semânticas presentes em conteúdos enviesados. Essa limitação é consistente com desafios identificados na literatura e reforça a necessidade de incorporar mecanismos mais avançados de análise.

A metodologia proposta para o desenvolvimento de segurança de prompts, estabelece um arcabouço sólido para futuras extensões, contudo algumas lacunas ainda podem ser exploradas. Devido a limitações das ferramentas, apenas prompts na linguagem inglesa são reconhecidos e tratados, portanto trabalhos futuros podem especializar a aplicação para outras linguagens, como o português. Para esse trabalho, algumas vulnerabilidades comuns em LLMs foram exploradas como PII, jailbreak e bias. Trabalhos futuros podem garantir a segurança para outros tipos de vulnerabilidades de prompts, dentre elas podemos citar a Data Exfiltration, Overloading Attack e Role-play Exploit. Essas vulnerabilidades exigem técnicas mais sofisticadas de desenvolvimento para a sua implementação, e podem ser exploradas em trabalhos futuros.

Referências

Benjamin, V., Braca, E., Carter, I., Kanchwala, H., Khojasteh, N., Landow, C., Luo, Y., Ma, C., Magarelli, A., Mirin, R., Moyer, A., Simpson, K., Skawinski, A., and Heverin, T. (2024).

Systematically analyzing prompt injection vulnerabilities in diverse llm architectures. *arXiv*, abs/2410.23308.

Chen, S., Piet, J., Sitawarin, C., and Wagner, D. (2025). Struq: Defending against prompt injection with structured queries. *USENIX Security Symposium*.

Hong, H., Feng, S., Naderloui, N., Yan, S., Zhang, J., Liu, B., Arastehfard, A., Huang, H., and Hong, Y. (2025). Sok taxonomy and evaluation of prompt security in large language models. *arXiv*, abs/2510.15476.

Lin, H., Lao, Y., Geng, T., Yu, T., and Zhao, W. (2025). Uniguardian: A unified defense for detecting prompt injection, backdoor attacks and adversarial attacks in large language models. *ArXiv*, abs/2502.13141.

Sebastian, G. (2023). Privacy and data protection in chatgpt and other ai chatbots: Strategies for securing user information. *IJSPPC*, 15.